Reporting

Executive Summary:

This project focused on identifying and exploiting vulnerabilities in a controlled lab environment using tools like Nmap, Metasploit, Burp Suite, SQLMap, and OWASP ZAP. Multiple critical vulnerabilities were discovered, including SQL Injection, Cross-Site Scripting (XSS), weak authentication, and insecure session management. These flaws allowed unauthorized access, data exposure, and even remote code execution. The findings highlight serious security weaknesses and emphasize the importance of secure coding practices, proper authentication mechanisms, and regular vulnerability assessments.

Technical Findings:

1. Session Fixation + XSS + RCE Chain:

- **Same session cookie before and after login → Session Fixation**
- **XSS confirmed via payload execution**
- **Exploited vsftpd 2.3.4 backdoor → Meterpreter shell access**

2. Weak Authentication:

- **Default credentials (admin:password) cracked via Burp Intruder.**

3. Insecure Cookie Configuration:

- **Missing Secure flag → vulnerable to interception**

4. Broken Access Control (BAC):

- **Improper session management → actions possible after logout**
- **IDOR → unauthorized data access**

5. SQL Injection (Blind + Error-based):

- **Extracted database info using SQLMap**
- **Critical data exposure risk**

6. Cross-Site Scripting (XSS):

- **Reflected, Stored, DOM-based XSS confirmed**
- **Allows execution of malicious scripts**

7. Unrestricted File Upload:

- **Uploaded malicious PHP reverse shell**
- **Achieved system-level access**

Remediation Plan:

Authentication

- **Enforce strong password policies**
- **Disable default credentials**

Session Management

- **Regenerate session IDs after login**
- **Invalidate sessions on logout/password change**

Input Validation

- **Sanitize all user inputs**
- **Use parameterized queries (prevent SQLi)**

XSS Protection

- **Output encoding**
- **Implement Content Security Policy (CSP)**

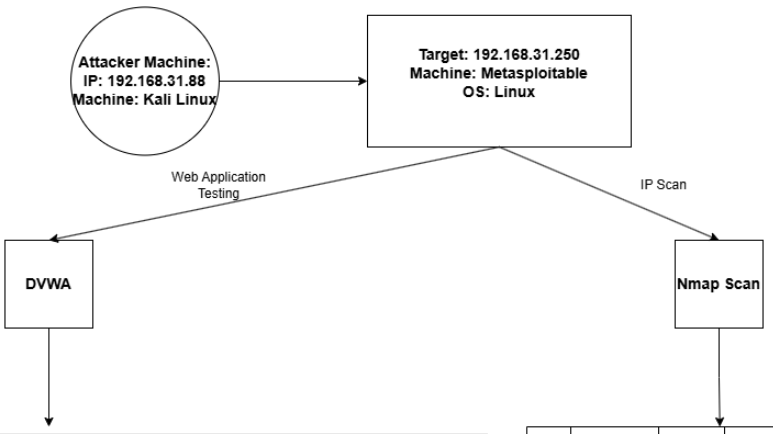
File Upload Security

- **Restrict file types**
- **Disable execution in upload directories**

System Hardening

- **Update vulnerable services (e.g., vsftpd)**
- **Use firewalls and IDS**

Summarizing Findings:



Test-ID	Vulnerability	Severity	Target URL
001	Insecure Cookie Configuration	Medium	http://127.0.0.1/DVWA/login.php
002	Broken Authentication	High to Critical	http://127.0.0.1/DVWA/login.php
003	Improper Session Management (BAC)	High	http://127.0.0.1/DVWA/vulnerabilities/authbypass/
004	Insecure Direct Object Reference (BAC)	Medium to High	http://127.0.0.1/DVWA/vulnerabilities/open_redirect/source/info.php?id=2
005	Broken Authentication and Session Management	Medium to High	http://127.0.0.1/DVWA/vulnerabilities/csrf/
006	Unrestricted File Upload	Critical	http://127.0.0.1/DVWA/vulnerabilities/upload/../../hackable/uploads/upload.php
007	SQL	High to Critical	http://127.0.0.1/DVWA/vulnerabilities/sqli/ & http://127.0.0.1/DVWA/vulnerabilities/sqli_blind/
008	XSS	High to Critical	http://127.0.0.1/DVWA/vulnerabilities/xss_d/, http://127.0.0.1/DVWA/vulnerabilities/xss_r/ & http://127.0.0.1/DVWA/vulnerabilities/xss_s/

S.No	Port No.	State	Service	Version
1	21/tcp	Open	Ftp	vsftpd 2.3.4
2	22/tcp	Open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1
3	23/tcp	Open	telnet	Linux telnetd
4	25/tcp	Open	smtp	Postfix smptd
5	53/tcp	Open	domain	ISC BIND 9.4.2
6	80/tcp	Open	http	Apache httpd 2.2.8
7	111/tcp	Open	rpcbind	2 (RPC #100000)
8	139/tcp	Open	netbios-ssn	smbd 3.X - 4.X
9	445/tcp	Open	netbios-ssn	smbd 3.0.20-Debian
10	512/tcp	Open	exec	-
11	513/tcp	Open	login	-
12	514/tcp	Open	tcpwrapped	-
13	1099/tcp	Open	java-rmi	GNU Classpath grmiregistry
14	1524/tcp	Open	bindshell	Metasploitable root shell
15	2049/tcp	Open	nfs	2-4 (RPC #100003)
16	2121/tcp	Open	ftp	ProFTPD 1.3.1
17	3306/tcp	Open	mysql	MySQL 5.0.51a-3ubuntu5
18	3632/tcp	Open	distccd	distccd v1
19	5432/tcp	Open	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
20	5900/tcp	Open	vnc	VNC (protocol 3.3)
20	6000/tcp	Open	x11	-
21	6667/tcp	Open	irc	UnrealIRCd
22	6697/tcp	Open	irc	UnrealIRCd
23	8009/tcp	Open	ajp13	Apache Jserv (Protocol v1.3)
24	8180/tcp	Open	http	Apache Tomcat/Coyote JSP engine 1.1
25	8787/tcp	Open	drb	Ruby DRb RMI
26	35623/tcp	Open	mountd	1-3 (RPC #100005)
27	40083/tcp	Open	java-rmi	GNU Classpath grmiregistry
28	50277/tcp	Open	nlockmgr	1-4 (RPC #100021)
29	58367/tcp	Open	status	1 (RPC #100024)

Finding ID	Vulnerability	CVSS Score	Remediation
001	SQL Injection	9.1	Use prepared statements
002	Weak Password	7.5	Enforce strong passwords
003	Cross-Site Scripting (XSS)	8.2	Input validation & encoding
004	Session Fixation	8.0	Regenerate session IDs
005	Insecure Cookie Configuration	6.5	Enable Secure & HttpOnly flags
006	Broken Access Control (IDOR)	7.8	Implement authorization checks
007	Unrestricted File Upload	9.5	Validate file type & restrict execution
008	Outdated Service (vsftpd 2.3.4)	10.0	Update/remove vulnerable service

Network Attack Path:

Attacker
DVWA Web Application
Session Fixation
XSS Injection
Credential Access / Cookie Theft
Nmap Scan
vsftpd 2.3.4 Exploit
Metasploit Shell Access
Full System Compromise

Non-Technical Summary:

The security assessment identified several critical weaknesses in the system that could allow attackers to gain unauthorized access and control. Issues such as weak passwords, insecure session handling, and outdated software significantly increase the risk of data breaches and system compromise. Attackers could exploit these flaws to steal sensitive information or take full control of the system. Immediate action is required to strengthen authentication, update vulnerable components, and implement secure coding practices. Regular security testing and monitoring are strongly recommended to prevent future attacks and ensure the overall safety and reliability of the system.